

基于检索增强生成的软件随机数发生器设计合规性 智能判定研究

检测室 顾伟平、刘兆

摘要：商用密码产品检测是保障国家信息安全的重要环节，其中软件随机数发生器的原理性审查因高度依赖专家经验而成为检测工作的难点。针对该问题，我们探索了基于大模型的智能辅助检测方法，通过将检测标准与专家经验结构化，并利用检索增强生成技术融入大模型推理过程，实现对产品技术性安全问题的自动化初筛与分析。最后，我们通过实验证明了方法有效性。

关键词 大模型，随机数产品，密码检测，检索增强生成

一、引言

《密码法》下的商用密码产品检测是我国信息化社会中保障信息安全的关键环节，是构筑国家信息安全长城的重要基石。随机数是密码安全的“源头活水”，密码产品检测常将其作为安全性检测的重中之重。但检测人员在软件随机数发生器的原理性审查过程中，由于该过程高度依赖检测人员具有丰富的知识储备和严谨规范的分析手段，导致其成为密码产品检测工作中核心部件安全性检测的难点，使得检测周期长、投入成本高。

近年来，虽然 GPT、DeepSeek、GLM 等大语言模型（Large Language Model，以下简称 LLM）^[1]持续取得突破性进展，展现出强大的通用能力，但由于缺乏商用密码等特定领域的专业知识，难以直接应用于软件随机数发生器等核心部件的原理性审查工作中^[2]。

本文以软件随机数发生器原理性审查方法作为实践案例，探索使

1 Minaee, S., Mikolov, T., Nikzad, N., Chenaghlu, M., Socher, R., Amatriain, X. and Gao, J., 2024. Large language models: A survey. arXiv preprint arXiv:2402.06196.

2 籍欣萌,咎红英,崔婷婷,等.大模型在垂直领域应用的现状与挑战[J].计算机工程与应用, 2025, 61(12):1-11.DOI:10.3778/j.issn.1002-8331.2409-0181.

用检索增强生成技术 (Retrieval-augmented Generation, 简称 RAG)^[3]来辅助检测的可行路径。主要贡献包括：抽象化了检测逻辑与规则，构建结构化的专家知识库；设计了思维链推理策略及提示词示例，可更好地应对单个检测任务中可能涉及到多条复杂逻辑与规则的情况；构建基于检索增强生成技术的智能辅助检测框架，使用专家知识库来增强大模型进而对送检材料进行智能初筛与安全性分析。实践表明，智能辅助检测框架有望成为检测人员的“智能增强”工具，可显著提升检测效率与规范性，为密码产品检测的智能化升级提供有益参考。

二、检测要点与检测难点

软件随机数发生器是软件密码模块(或混合密码模块的软件部件)中的随机数发生器部件，可以单独作为软件密码模块，也可以作为软件密码模块(或混合密码模块的软件部件)的一部分，其生成随机数的质量直接关系到现已有的许多软件密码模块的密钥安全性。本节就软件随机数发生器的检测要点和存在的问题难点进行分析介绍。

(一) 检测要点

根据 GM/T 0105-2021《软件随机数发生器设计指南》，软件随机数发生器的基本模型主要包括熵源、熵估计、熵池、确定性随机数发生器 (Deterministic Random Number Generator, 以下简称 DRNG) 和健康测试等部分，可见图 1。其中，DRNG 主要由内部状态、初始化函数、重播种函数、输出函数、自测试等基本部件组成。

[3] Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., ... & Kiela, D. (2020). Retrieval-augmented generation for knowledge-intensive nlp tasks. *Advances in neural information processing systems*, 33, 9459-9474.

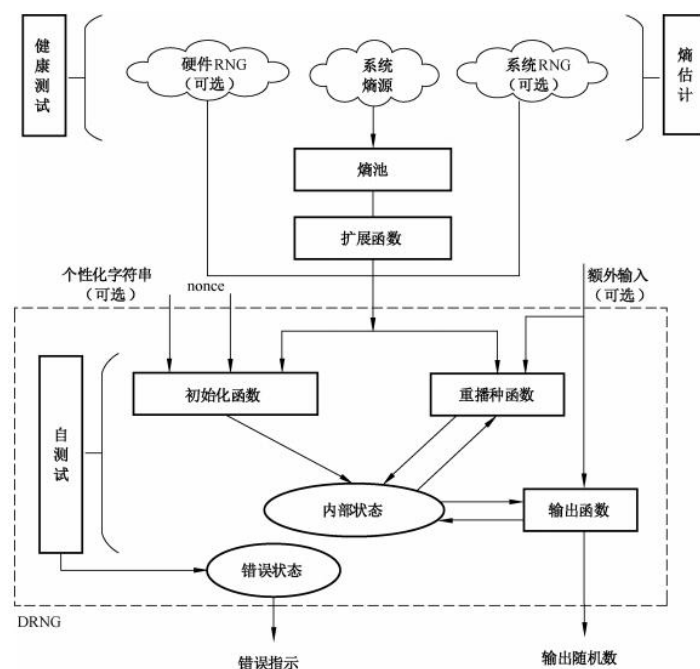


图 1 软件随机数发生器的基本模型

软件随机数发生器的检测要点包含以下 6 个关键内容：

1. 软件随机数发生器组成需审查架构组成的完整性和模块间功能的协调性；
2. 熵源作为随机数生成的根源，需审查其多样性、随机性和极端条件下的熵输入充足性；
3. 熵池需审查熵池大小、熵池结构和熵数据更新方案的有效性；
4. 熵估计需审查熵估计方法的科学性；
5. 健康测试需审查健康测试方法的科学性；
6. DRNG 需审查实现逻辑，并对输出结果进行统计随机性检验。

（二）检测难点

在实际检测中，如何高效、准确且无遗漏地完成从文档审查到技术验证的全流程，是提升检测效能的关键瓶颈，主要存在以下个难点：

1. 对送检单位提供的设计文档、源码说明等材料进行标准符合性及安全性审查高度依赖检测人员的经验。一份软件随机数发生器材料

可能长达数百页，其中关键信息往往分散在不同章节。反复翻阅、交叉比对的过程不仅耗时费力，更易导致关键信息遗漏。例如，在审查熵源时，送检企业可能在“概述”章节笼统列举合规的熵源，却在“详细设计”中实际使用了“硬盘序列号”等不合规的熵源，而人工审查极易忽略此类细节，存在漏判的风险。

2.标准规范上仍存在需要检测人员基于专业知识储备进行解读和判断的具体内容。例如，“可选”要求、某些主观判断的“特定”情况等判断往往缺乏明晰的标尺，使得不同检测人员审查同一份材料的判断可能产生分歧，导致检测结果的客观性与一致性存疑。

3.为确保软件随机数发生器的鲁棒性，需模拟各种异常和极端条件进行测试。例如，模拟熵源失效、熵池枯竭或持续输出大量随机数等测试场景设计测试用例时，检测人员很难穷尽此类可能性常规情况。开发这些测试用例通常需要编写复杂的脚本程序，工作量大且复用性低，测试覆盖性不足。

综上所述，传统人工检测模式从文档初审、深度分析到测试验证，整个检测周期长，人员培养上手难，难以应对日益增长的密码产品检测需求。因此，探索如何利用 LLM 来应对上述难点，将其作为辅助检测的工具，以提升审查检测效能，最终构建一个更高效、更专业、更客观的密码产品检测新模式，不仅具有理论价值，更具备紧迫的现实意义。

三、基于 LLM 的智能辅助检测框架

为解决传统人工检测模式效率低、通用 LLM 缺乏领域知识的问题，本文提出基于 LLM 与检索增强生成的智能辅助检测框架，构建专家知识库对送检材料进行智能初筛与安全性分析。本框架主要包括

三个核心环节：检测目标的精细化定义、专家知识库的构建与抽象、以及基于思维链的推理与提示机制，三者层层递进，共同构成从“检测什么”到“如何判断”再到“怎样推理”的完整流程。

（一）检测目标的精细化定义

智能辅助检测框架参考 GM/T 0105-2021 《软件随机数发生器设计指南》，针对软件随机数发生器的检测要点进行了检测目标的细粒度定义：

- 1.随机数发生器组成：审查随机数发生器组成是否合理；
- 2.熵源：审查熵源采集原理是否合理、系统熵源数量是否满足不少于 3 种、熵源独占性设计是否合理；
- 3.熵池：审查熵池大小是否满足 512-4096 字节、扩展函数是否选取有效；
- 4.熵估计：审查最小熵评估方法是否选取合理有效；
- 5.健康测试：审查上电健康测试、连续健康测试和按需健康测试方法是否合理有效；
- 6.DRNG：审查 DRNG 设计实例是否合理有效。

（二）专家知识库的构建与抽象

检测目标定义了“要做什么”，而专家知识则定义了“如何判断”。结合日常工作经验，智能辅助检测框架针对上述检测目标系统性地梳理了其检测逻辑与规则。部分逻辑与规则定义举例如下：

- 1.规则 1：若材料中熵源相关内容描述中出现“硬盘序列号”、“CPU 序列号”、“MAC 地址”等关键词，判定为“不符合”。
- 2.规则 2：统计系统熵源种类数量，若少于 3 种，判定为“不符合”。

3.规则 3: 材料中是否描述了在无人机交互情况下熵源采集原理,若无判定为“不符合”。

通过抽象化的检测逻辑与规则,结合标准规范原文片段和典型案例,智能辅助检测框架将常见的“符合/不符合”判断构建成一个结构化的专家知识库。

(三) 基于 RAG 的评测任务执行

在实际使用智能辅助检测框架对一个具体的材料进行审查时,采用 RAG 方法来动态地激活和运用专家知识库,为了应对单个评测任务中可能涉及多条复杂规则的情况,并确保模型推理过程的严谨、透明与可追溯,引入了思维链推理策略。其核心流程如下:

- 1.任务解析与检索: 解析检测目标,从专家知识库中检索相关逻辑与规则;
- 2.结构化提示: 结合专家知识,要求智能辅助检测框架按步骤对检测目标和材料进行推理;
- 3.思维链分析: 智能辅助检测框架依次使用每条规则对材料内容进行判断,经过多次推理,最终输出结论。

在上述推导过程中,通过 RAG 方法将专家知识进行获取与封装,构建针对特定任务的提示词,然后让 LLM 扮演检测专家的角色对产品安全性设计进行精准分析,并最终反馈检测结果。本文的提示词示例如表 1 所示:

表 1: 提示词示例

角色	你是一名商用密码检测专家。请严格遵循一步步方式按照推理步骤对材料进行每个规则是否符合的分析。
检测目标	{插入具体的检测目标,例如熵源的检测目标}
专家知识	规则 1: {检索规则 1,若材料中熵源相关内容描述中出现“硬盘序列号”、“CPU 序列号”、“MAC 地址”等关键词,判定为“不符合”} 规则 2: {……} 规则 3: {……}

任务	请严格依据上述检测目标和专家知识，对以下材料进行符合性判断。
材料	{检索材料中关于熵源描述的原文段落}
输出要求	输出结果应如下： 1. 符合性结论（符合/不符合）。 2. 详细理由，逐条引用规则进行分析。

四、实验结果与分析

为验证智能辅助检测框架的可行性和有效性，本文设计并执行了如下对比实验：

（一）实验设置

检测模型：选取了 DeepSeek-V3.2 和 GLM-4.5 两种大型语言模型。

测试样本：围绕软件随机数发生器的 6 个检测要点，构建了一个包含 50 个测试样本的数据集，主要包括以下 3 种类型：

1. 正确样本：完全符合 GM/T 0105-2021 的安全设计内容；
2. 不完整样本：安全性设计材料上缺失了检测要点相关内容；
3. 错误样本：包含不符合标准规范的安全性设计内容。

对比方法：设置了原版模型和智能辅助检测框架模型两种方式对同测试样本的数据集进行审查，对比输出结果的准确性。其中，原版模型直接使用检测目标和材料向 LLM 提问进行审查；智能辅助检测框架模型采用本文第三章流程对材料进行审查。

评价指标：通过对比两种审查方式输出结果与标准答案一致性，统计准确率。

（二）实验结果

通过对比实验，原版模型对材料审查的输出结果与标准答案一致的准确率分别达到了 40%和 36%，智能辅助检测框架模型对材料审查的输出结果与标准答案一致的准确率分别达到了 94%和 88%，两种审查方式的准确率如表 2 所示：

表 2 准确率对比统计表

检测模式	DeepSeek-V3.2	GLM-4.5
原版模型	40%	36%
智能辅助检测框架模型	94%	88%

（三）实验结果分析

从实验结果可以发现，本文设计的智能辅助检测框架无论使用 DeepSeek-V3.2 还是 GLM-4.5 大语言模型，其对材料中安全性设计审查准确率均比直接使用大语言模型更高，这充分证明了智能辅助检测框架的可行性和有效性。其中，本文针对审查输出结果与标准答案不一致的样本进一步深入分析，发现错误的原因主要集中于一些需要深层逻辑推导或材料描述极度模糊的情况。因此，如何解决此类问题是本文将来进一步研究的方向。

五、讨论与总结

本文通过构建智能辅助检测框架，在保障密码产品检测规范性的同时，为提升检测效率提供了新的可行路径。通过实践证明，该框架在软件随机数发生器原理性审查上达到了较高水平的准确率，但极端情况下的安全性审查在现阶段仍需要人工的参与。

本文选取方法充分考虑了在中心实际应用可行性。采用的 DeepSeek 与 GLM 等开源大模型支持离线部署，并已适配华为昇腾、寒武纪、海光信息等国产算力平台，可实现完全内网运行，确保检测数据不出域，符合安全可控要求。

通过本文大语言模型在密码产品检测中的实践探索案例分析，亟须结合大语言模型进一步为密码检测事业注入新的活力，将来基于大语言模型研制出辅助检测人员进行材料审查、密码安全性分析、源码

实现分析、漏洞扫描挖掘、检测报告审核等每一关键检测环节的“智能增强”工具，进一步使得检测方法更专业、检测工具更智能、检测过程更规范，积极推动密码检测迈向新的检测模式。